

Mapeo normativo detallado de indicadores y métricas GQM

Tabla de correspondencia entre los 15 indicadores OCTAVE nacionales, sus objetivos GQM y los principales marcos normativos (ENS, NIS2, ISO, RGPD, NIST CSF).

1. Leyenda

- ENS: Esquema Nacional de Seguridad (RD 311/2022).[web:60][web:63][web:71]
- NIS2: Directiva (UE) 2022/2555 y normativa de desarrollo.
- ISO 27001: ISO/IEC 27001:2022 (SGSI).
- ISO 27005: Gestión de riesgos de seguridad de la información.
- ISO 22301: Gestión de continuidad de negocio.
- RGPD: Reglamento (UE) 2016/679 y LOPDGDD.
- NIST CSF: NIST Cybersecurity Framework 2.0.[web:66]
- OCTAVE: familia OCTAVE (clásico, Allegro, FORTE).

2. Tabla de mapeo

Nº	Indicador / Objetivo GQM resumido	ENS	NIS2	ISO / NIST	RGPD	OCTAVE / otros	Comentario de alineamiento
1	Inventario de servicios esenciales digitalizados – Evaluar identificación y gestión de activos críticos nacionales	ENS art. 10, Anexo II (inventario de activos); ENS principios de gestión basada en riesgos	NIS2 arts. 20–21 (gestión de riesgos y medidas técnicas); requisitos para operadores esenciales	ISO 27001 Anexo A.5.9 (inventario de activos), NIST CSF ID.AM (Asset Management)	–	OCTAVE Allegro (perfilado de activos y contenidos)	El indicador materializa la exigencia de identificar activos que sostienen servicios esenciales y analizarlos como base del riesgo.
2	Cobertura ENS en administraciones – Medir implantación ENS	ENS RD 311/2022 completo; Anexo II (medidas por categoría)	NIS2 (extensión de obligaciones a operadores públicos)	ISO 27001 (SGSI en AA.PP. que adopten ISO además de ENS)	–	OCTAVE clásico/FO RTE (gestión de riesgos institucional)	La métrica refleja cumplimiento del marco ENS, utilizado como referencia nacional para AA.PP. y muchos proveedores. [web:90] [web:87]

3	Protección de datos personales – Cobertura EIPD y medidas ENS/RGPD	ENS art. 4 (seguridad de la información), Anexo II (medidas de protección)	NIS2 (protección de datos como componente del riesgo)	ISO 27001 Anexo A.5–A.8 (controles de protección de información)	RGPD arts. 24, 25, 32–34 (responsabilidad proactiva, seguridad del tratamiento, notificación de brechas)	OCTAVE (evaluación de impacto y criticidad de activos de datos)	Conecta gestión de riesgo ENS/ISO con obligaciones RGPD sobre seguridad de datos y brechas.
4	Incidentes por sector – Distribución sectorial de riesgo materializado	ENS art. 31–32 (registro y notificación de incidentes)	NIS2 arts. 23–24 (notificación de incidentes significativos)	ISO 27035 (gestión de incidentes), NIST CSF DE/RS	RGPD art. 33 (notificación de violaciones de datos)	OCTAVE (identificación de amenazas y materialización de riesgos)	Métrica central para cumplir y monitorizar obligaciones de incidente, priorizando sectores.
5	Tendencia de incidentes nacionales – Evolución de exposición global	ENS art. 10 (reevaluación continua), informes INES	NIS2 (monitoreo de riesgos a nivel de entidad y sector)	ISO 27001 cl. 9 (evaluación del desempeño); NIST CSF ME (Monitoring and Evaluation)	–	ENISA Threat Landscape, OCDE medición de ciberseguridad[web:51] [web:19]	Indicador macro que evalúa si el conjunto del sistema está contenido o no la frecuencia de incidentes.

6	Amenazas contra disponibilidad – Prevalencia de ataques a disponibilidad	ENS principios de disponibilidad y continuidad; Anexo II medidas de continuidad	NIS2 (disrupción de servicios como criterio de incidente significativo)	ISO 22301 (continuidad), NIST CSF PR.PT/RS	–	OCTAVE (impacto en disponibilidad como criterio de impacto clave)	Alineado con el foco en continuidad de servicios esenciales en ENS, NIS2 y marcos de resiliencia.
7	Sistemas vulnerables detectados – Superficie de exposición técnica	ENS Anexo II (gestión de vulnerabilidades y configuración)	NIS2 (medidas de gestión de riesgos, incluyendo vulnerabilidades)	ISO 27001 Anexo A.8.8 (gestión de vulnerabilidades), NIST CSF PR.IP-12	–	OCTAVE (identificación de vulnerabilidades de activos)	Métrica directa de cumplimiento de prácticas de gestión de vulnerabilidades exigidas por ENS/ISO/NIS2.
8	Exposición de servicios esenciales – Vulnerabilidades críticas sin parchear	ENS art. 10, Anexo II (medidas reforzadas para sistemas de alta criticidad)	NIS2 (obligaciones reforzadas para entidades esenciales)	ISO 27001, NIST CSF PROTECT /DETECT	–	OCTAVE (priorización de riesgos de alto impacto)	Mide el gap entre criticidad de servicios esenciales y estado de parcheo; altamente relevante regulatoriamente.

9	Brechas de capacidad – Sectores en "zona de riesgo" (crit. alta, madurez baja)	ENS (necesidad de recursos adecuados), planes nacionales de ciberseguridad	NIS2 (capacidad organizativa, recursos, supervisión)	ENISA NIS360, EU-Cybersecurity Index[web:19] [web:21]	–	OCTAVE FORTE (capacidad organizativa y programa de riesgos)	Conecta la evaluación de madurez sectorial con requisitos de capacidad y supervisión.
10	Gobernanza y liderazgo – Existencia y actividad de órganos de gobierno	ENS art. 7 (función de seguridad, roles y responsabilidades)	NIS2 art. 20 (responsabilidad de la dirección)	ISO 27001 cl. 5 (liderazgo), NIST CSF GOV	–	OCTAVE FORTE (implicación de la alta dirección)	Mide hasta qué punto las obligaciones de liderazgo y gobernanza se han traducido en estructuras reales.
11	Capacidad de respuesta nacional – Tiempo de respuesta de CSIRTs	ENS (coordinación con CCN-CERT/INCIBE-CERT), protocolos de notificación	NIS2 (CSIRTs nacionales, capacidades de respuesta)	ISO 27035, NIST CSF RS	–	OCTAVE (planes de respuesta y mitigación)	Indicador clave para evaluar la efectividad real de los CSIRTs nacionales frente a incidentes.

12	Cultura y formación – Programas de concienciación y formación	ENS principios de seguridad integral y concienciación	NIS2 (formación del personal, cultura de seguridad)	ISO 27001 cl. 7.2 (competencia), NIST CSF PR.AT	–	OCDE/ENISA sobre capacidad y cultura[web:19] [web:51]	Alinea competencias humanas con requisitos normativos de formación y cultura de seguridad.
13	Pérdidas económicas estimadas – Impacto económico agregado de ciberincidentes	ENS (análisis de impacto), Plan Nacional de Ciberseguridad	NIS2 (evaluación de impacto de incidentes significativos)	OCDE – medición de impacto económico o de ciberincidentes[web:51] [web:92]	–	OCTAVE (criterios de impacto financiero)	Conecta medición económica con factores de riesgo y priorización de inversiones.
14	Continuidad de servicios esenciales – Interrupciones significativas por ciberincidentes	ENS (continuidad y disponibilidad de servicios), Esquema de Seguridad de la Administración de Justicia[web:53]	NIS2 (servicios esenciales y continuidad)	ISO 22301, NIST CSF ID/PR/RS	–	OCTAVE (impacto en continuidad como criterio central)	Métrica de resultado para evaluar el cumplimiento del mandato de mantener servicios esenciales.

15	Confianza digital – Percepción de confianza en servicios digitales	Estrategia Nacional de Ciberseguridad (objetivos de confianza y uso seguro)	NIS2 (confianza en redes y sistemas como objetivo general)	Encuestas ENISA, OCDE sobre confianza digital[web:51][web:19]	–	–	Indicador "socio-técnico" que enlaza el desempeño de la ciberseguridad con la adopción y confianza en servicios digitales.
----	--	---	--	---	---	---	--

3. Uso del mapeo en el ciclo GQM

- Cada objetivo GQM se puede anotar con las referencias normativas que lo respaldan, reforzando su legitimidad ante decisores y auditores.
- Las métricas que se vinculan a múltiples marcos (ENS, NIS2, ISO) adquieren prioridad, al reducir simultáneamente riesgo operativo y riesgo de cumplimiento.[web:60][web:84][web:93]
- El mapeo facilita la elaboración de informes de adecuación orientados a reguladores, demostrando cómo el sistema nacional de indicadores OCTAVE GQM+PRAGMATIC responde al ecosistema normativo vigente.

En resumen, este mapeo evita que los indicadores parezcan ocurrencias aisladas: los sitúa, con nombre y apellidos, en el tejido normativo que regula la ciberseguridad nacional.